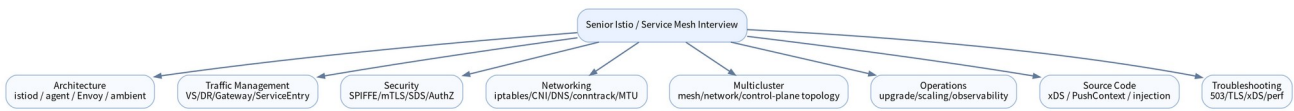


# Senior Istio / Service Mesh Interview Handbook

从 Kubernetes Service Mesh 到 Istio Sidecar、Ambient、Multicluster 与源码级排障 | 2026 Final Edition



面试知识地图：从架构、流量、安全到源码与跨集群排障

**定位** 面向 Senior/Staff Infrastructure、Kubernetes、Service Mesh、Platform、SRE 面试。重点不是背 API，而是能够解释数据路径、控制路径、配置如何编译成 Envoy xDS、故障如何从应用一路定位到内核与网络。

研究基线：Istio 1.30（2026-05 发布，支持 Kubernetes 1.32-1.36）及 2026-08 的最新官方文档；同时覆盖 Sidecar 与 Ambient 两种数据平面。1.30 还引入了实验性的 agentgateway GatewayClass，用于 AI Agent / MCP gateway 流量。

| 层级                      | 必须掌握                                            | Staff 级深化                                 |
|-------------------------|-------------------------------------------------|-------------------------------------------|
| L1 Linux/Network        | TCP、DNS、iptables/nftables、contrack、MTU、TLS      | 抓包、内核队列、连接跟踪、LB/SG/NACL 联动                |
| L2 Kubernetes           | Service/EndpointSlice、Admission、CNI、Gateway API | Informer、Webhook、网络模型、多集群 API 可达性         |
| L3 Istio Control Plane  | istiod、xDS、CA、config validation                 | PushContext、增量推送、配置依赖图、性能/规模              |
| L4 Data Plane           | Envoy sidecar、istio-agent、ztunnel、waypoint      | Listener/Route/Cluster/Endpoint、HBONE、SDS |
| L5 Ops                  | 流量治理、安全、可观测性、升级                                 | 多集群、SLO、容量、故障注入与演练                        |
| L6 Source/System Design | 源码路径、故障树、架构设计                                   | 百万 Pod/多集群/多租户/AI Gateway 场景              |

## 0. 如何使用这本手册

建议按三轮使用：第一轮构建数据路径与控制路径；第二轮按专题完成实验；第三轮用面试问答树做 2 分钟与 10 分钟口述训练。

| 阶段                  | 目标                                            | 输出                                         |
|---------------------|-----------------------------------------------|--------------------------------------------|
| 第 1 轮：架构            | 能手画 sidecar/ambient/multicluster 数据路径         | 不看资料画出组件图并解释每条箭头                           |
| 第 2 轮：配置            | 能从 VirtualService/DestinationRule 推导 Envoy 行为 | 用 istioctl proxy-config 验证 LDS/RDS/CDS/EDS |
| 第 3 轮：排障            | 面对 503/TLS/xDS/跨集群问题建立假设树                     | 命令、指标、日志、抓包形成证据闭环                          |
| 第 4 轮：源码            | 能定位 Pilot/agent/injector/ambient 关键代码         | 从事件到 Push 到 xDS 到 Envoy ACK/NACK           |
| 第 5 轮：System Design | 设计多集群/高流量/安全 mesh                             | 明确 trade-off、容量、故障域、升级/回滚                  |

# 1. Service Mesh 与 Istio 核心模型

## 1.1 为什么需要 Service Mesh

Service Mesh 将服务间通信中的连接管理、mTLS、流量治理、遥测与策略从业务进程中下沉到基础设施层。其价值不是“多一个代理”，而是把分布式系统中重复且容易不一致的网络能力统一实现。

- 服务发现与负载均衡：将 Kubernetes Service/EndpointSlice 转换成数据平面可用的 endpoint 集。
- 安全：工作负载身份、证书轮转、双向 TLS、细粒度 AuthorizationPolicy。
- 流量治理：权重、Header/URI 匹配、重试、超时、熔断、异常实例剔除、局部性路由。
- 可观测性：标准化请求指标、访问日志和 trace 上下文传播。
- 迁移与多集群：把“网络边界”和“集群边界”抽象为可编程拓扑。

## 1.2 Istio 的控制平面 / 数据平面

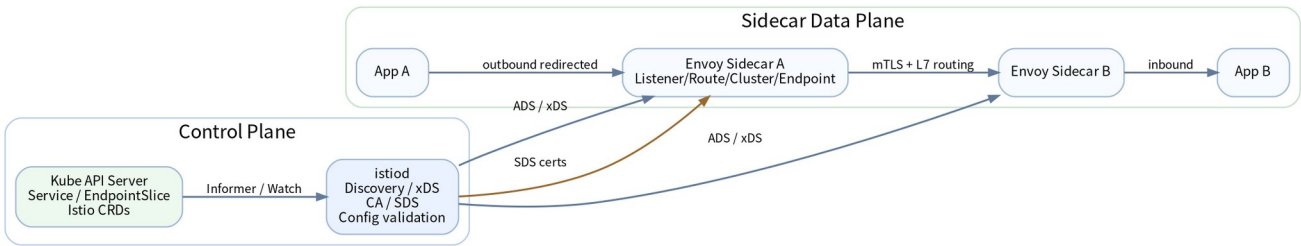


图 1: Sidecar 模式的核心控制路径与数据路径

控制平面的职责是“观察期望状态并编译配置”，数据平面的职责是“按配置转发流量”。请求不会经过 istiod；istiod 不在业务请求的同步链路中，这也是面试中极高频的边界问题。

**高频追问** 如果 istiod 全部宕机，已有 sidecar 通常还能继续按最后一次成功接收的配置转发，但新配置、证书续期、新 Pod 引导、部分服务发现更新会受影响；因此控制平面故障与数据平面故障的影响窗口不同。

## 1.3 Sidecar 与 Ambient 的根本差异

| 维度        | Sidecar                  | Ambient                               |
|-----------|--------------------------|---------------------------------------|
| 代理粒度      | 每 Pod 一个 Envoy sidecar   | 每 Node 一个 ztunnel；需要 L7 时再经过 waypoint |
| L4 安全     | Envoy sidecar 处理         | ztunnel 处理                            |
| L7 路由/策略  | sidecar Envoy            | waypoint Envoy                        |
| 应用 Pod 侵入 | 需要注入 sidecar/volumes/env | 不注入 sidecar                           |
| 升级        | 随 workload 重启升级 sidecar  | ztunnel/waypoint 独立升级                 |
| 资源模型      | 代理数量与 Pod 数近似线性          | 基础 L4 代理与 Node 数更相关                   |

## 2. istiod 内部架构与配置编译链

### 2.1 istiod 不是一个单一功能模块

现代 Istio 将历史上的 Pilot、Citadel、Galley 等能力聚合到 istiod 进程中，但逻辑职责仍然可以拆分为：平台服务发现、Istio CRD 配置存储与验证、xDS 生成与分发、CA/证书签发、Webhook 注入与配置校验等。

| 模块                  | 输入                                                     | 输出                               | 面试关注点                             |
|---------------------|--------------------------------------------------------|----------------------------------|-----------------------------------|
| Kubernetes Registry | Service、Pod、EndpointSlice                              | ServiceInstance / endpoint model | Informer、一致性、EndpointSlice 事件     |
| Config Store        | VirtualService、DestinationRule、Gateway、ServiceEntry... | 统一配置模型                           | 作用域、exportTo、host 解析              |
| Discovery Server    | Proxy metadata + config/model changes                  | LDS/CDS/RDS/EDS                  | ADS、ACK/NACK、push scope           |
| CA/Security         | ServiceAccount identity / CSR                          | workload certificate             | SPIFFE、root/intermediate、rotation |
| Webhook             | Pod admission request                                  | mutated PodSpec                  | revision、template、failurePolicy   |

### 2.2 从 Kubernetes 事件到 Envoy 配置

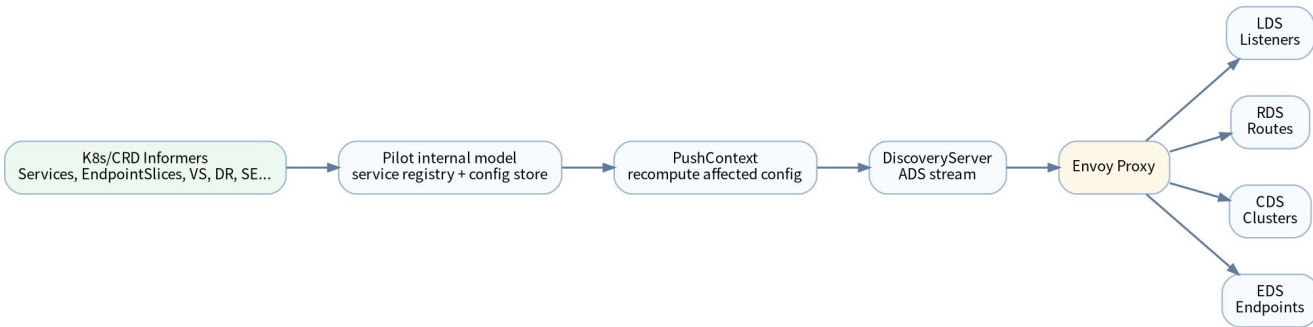


图 2: Informer -> Pilot model -> PushContext -> DiscoveryServer -> Envoy xDS

真正需要理解的不是“istiod 下发 xDS”，而是哪些事件需要 full push，哪些可做更小范围的增量更新；服务、endpoint、VirtualService、DestinationRule 的依赖关系决定 push 范围。规模越大，减少无关 proxy 的配置与 push 扇出越重要。

#### 2.2.1 ACK / NACK

Envoy 接收 xDS 资源后会 ACK 成功版本；若资源无法解析或验证失败则 NACK。排障时 proxy-status 能看到 SYNCED/STALE/NOT SENT 等状态，Envoy/istiod 日志中的 nonce、version 与 NACK error 可以定位是哪类资源失败。

### 3. Sidecar 注入与 Pod 启动源码链

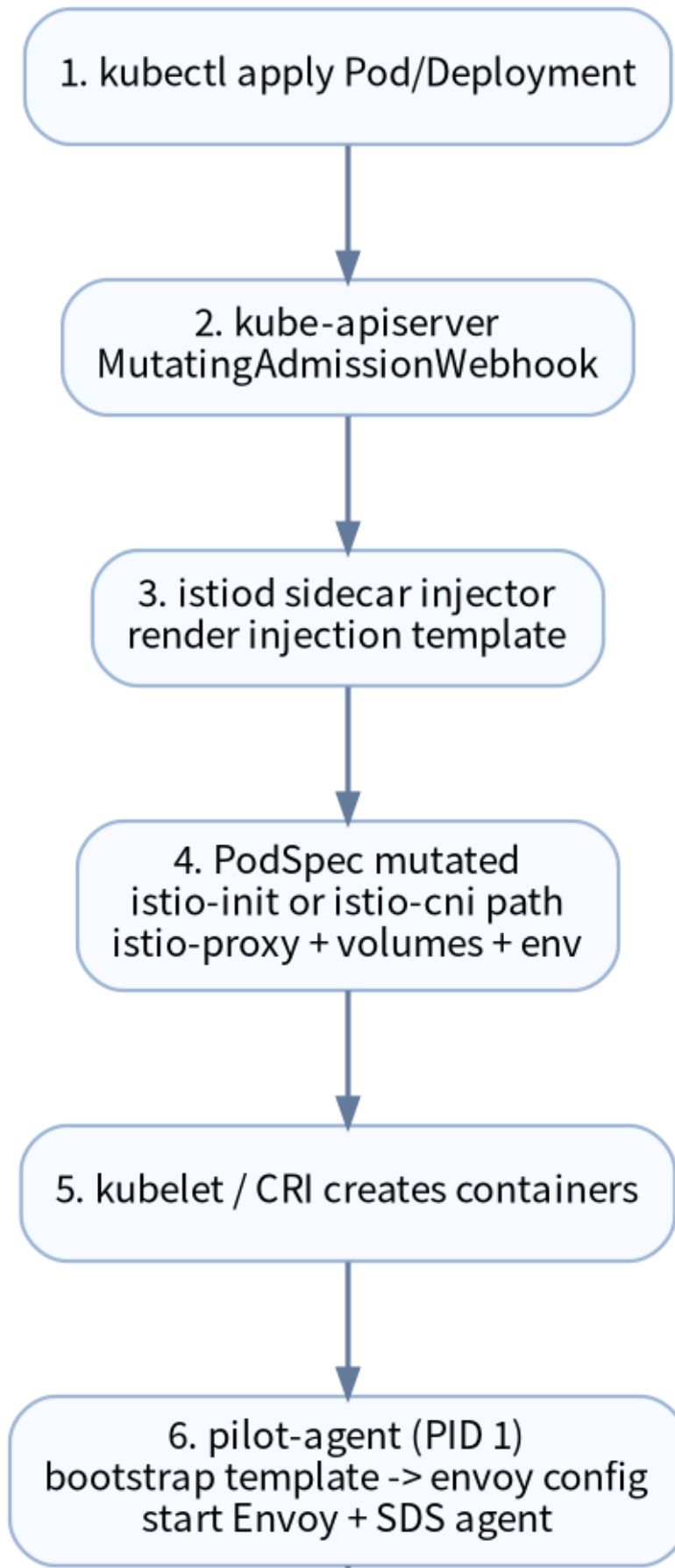


图 3: 从 `kubectl apply` 到 `pilot-agent`、`Envoy Ready` 的完整链路

### 3.1 MutatingAdmissionWebhook

启用自动注入后，`kube-apiserver` 在 Admission 阶段调用 `istiod` 的 `sidecar injector webhook`。Injector 根据 `namespace/pod label`、`revision`、模板和 `values` 决定是否注入，并生成 `istio-proxy`、`init/CNI` 相关注解、共享 `volume`、环境变量以及 `readiness` 配置。

### 3.2 pilot-agent 的角色

- 作为 `istio-proxy` 容器 PID 1 的上层 agent，负责构造/管理 `Envoy` 启动参数和 `bootstrap`。
- 为 `Envoy` 提供 `SDS` 证书接口，协调 `workload identity` 与证书轮换。
- 维护 `status/health/admin` 辅助逻辑，并负责 `Envoy` 进程生命周期。
- 建立到 `istiod` 的发现/证书相关连接，向 `Envoy` 提供本地代理能力。

### 3.3 启动阶段常见失败

| 症状                                | 可能层                                                                 | 验证                                                                                  |
|-----------------------------------|---------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Pod Init 卡住                       | <code>istio-init</code> / <code>iptables</code> / <code>CNI</code>  | <code>describe pod</code> 、 <code>CNI daemon 日志</code> 、 <code>iptables-save</code> |
| <code>istio-proxy NotReady</code> | <code>xDS</code> / <code>SDS</code> / <code>bootstrap</code>        | <code>pilot-agent 日志</code> 、 <code>15000/15021</code> 、 <code>proxy-status</code>  |
| <code>Envoy</code> 无 endpoint     | 服务发现/ <code>EndpointSlice</code> / <code>Sidecar scope</code>       | <code>proxy-config endpoints/clusters</code>                                        |
| 证书获取失败                            | <code>JWT audience</code> 、 <code>CA</code> 、 <code>RBAC</code> 、时间 | <code>proxy-config secret</code> 、 <code>istiod CA 日志</code>                        |

## 4. 流量劫持：iptables、TPROXY、Istio CNI 与端口模型

### 4.1 Sidecar 数据路径

```
Application outbound connect()
-> iptables OUTPUT/ISTIO_OUTPUT
-> redirect to Envoy 15001
-> virtual outbound listener
-> route/cluster/endpoint
-> upstream
```

Inbound:

```
NIC -> PREROUTING/ISTIO_INBOUND -> Envoy 15006 -> application port
```

理解 15001、15006、15090、15021、15000 等端口的用途，是解释 sidecar 网络路径和排障的基础。要进一步理解 UID/GID exclusion、loop avoidance、DNS capture、TPROXY/REDIRECT 差异。

### 4.2 istio-init vs Istio CNI

传统 initContainer 需要 NET\_ADMIN/NET\_RAW 等能力来写规则；Istio CNI 将 Pod 网络重定向配置下沉到 node CNI 链路，减少应用 Pod 的特权需求。Ambient 模式则进一步依赖 istio-cni node agent 完成 transparent capture 与 ztunnel 之间的流量导向。

### 4.3 面试中的网络底层追问

- 为什么应用自己访问 127.0.0.1 不应被无限重定向？如何避免 Envoy 自己的流量再次进入 Envoy？
- 如果 Service ClusterIP 可达但 sidecar 注入后不可达，应如何区分 iptables 问题和 xDS 问题？
- MTU 过小、overlay、mTLS、HBONE 叠加时为什么可能出现大包失败但 ping 正常？
- conntrack 表耗尽为什么会表现为新连接失败，而已有连接可能正常？

## 5. Envoy 内部模型：Listener -> Route -> Cluster -> Endpoint



图 4：一条 HTTP 请求在 Envoy 配置对象中的路径

### 5.1 LDS/CDS/RDS/EDS 应该怎么记

| xDS | 核心对象                             | 回答问题                                   | 常用命令                 |
|-----|----------------------------------|----------------------------------------|----------------------|
| LDS | Listener / FilterChain           | 在哪个端口接收、按什么协议处理？                       | istioctl pc listener |
| RDS | RouteConfiguration / VirtualHost | HTTP 请求匹配到哪里？                          | istioctl pc route    |
| CDS | Cluster                          | 上游服务如何连接、LB/TLS/熔断怎么做？                 | istioctl pc cluster  |
| EDS | ClusterLoadAssignment            | 具体有哪些 endpoint、locality/weight/health？ | istioctl pc endpoint |
| SDS | Secret                           | 证书和 root bundle 是什么？                   | istioctl pc secret   |

### 5.2 ADS 为什么重要

ADS（Aggregated Discovery Service）允许多类 xDS 资源在同一 gRPC stream 上交互，并帮助控制依赖顺序。面试中常问“为什么 CDS/EDS/RDS/LDS 不是四条独立连接”；回答要落到一致性、依赖、版本与推送效率。

### 5.3 Outbound cluster 命名

```
outbound|<port>|<subset>|<service FQDN>
inbound|<port>||
BlackHoleCluster / PassthroughCluster
```

看到 Envoy access log 或 cluster stats 时，应能从 cluster name 反推 DestinationRule subset、service host 与端口；这对分析 UH/UF/UO 等 response flag 很关键。

## 6. Traffic Management : VirtualService 与 DestinationRule 的编译语义

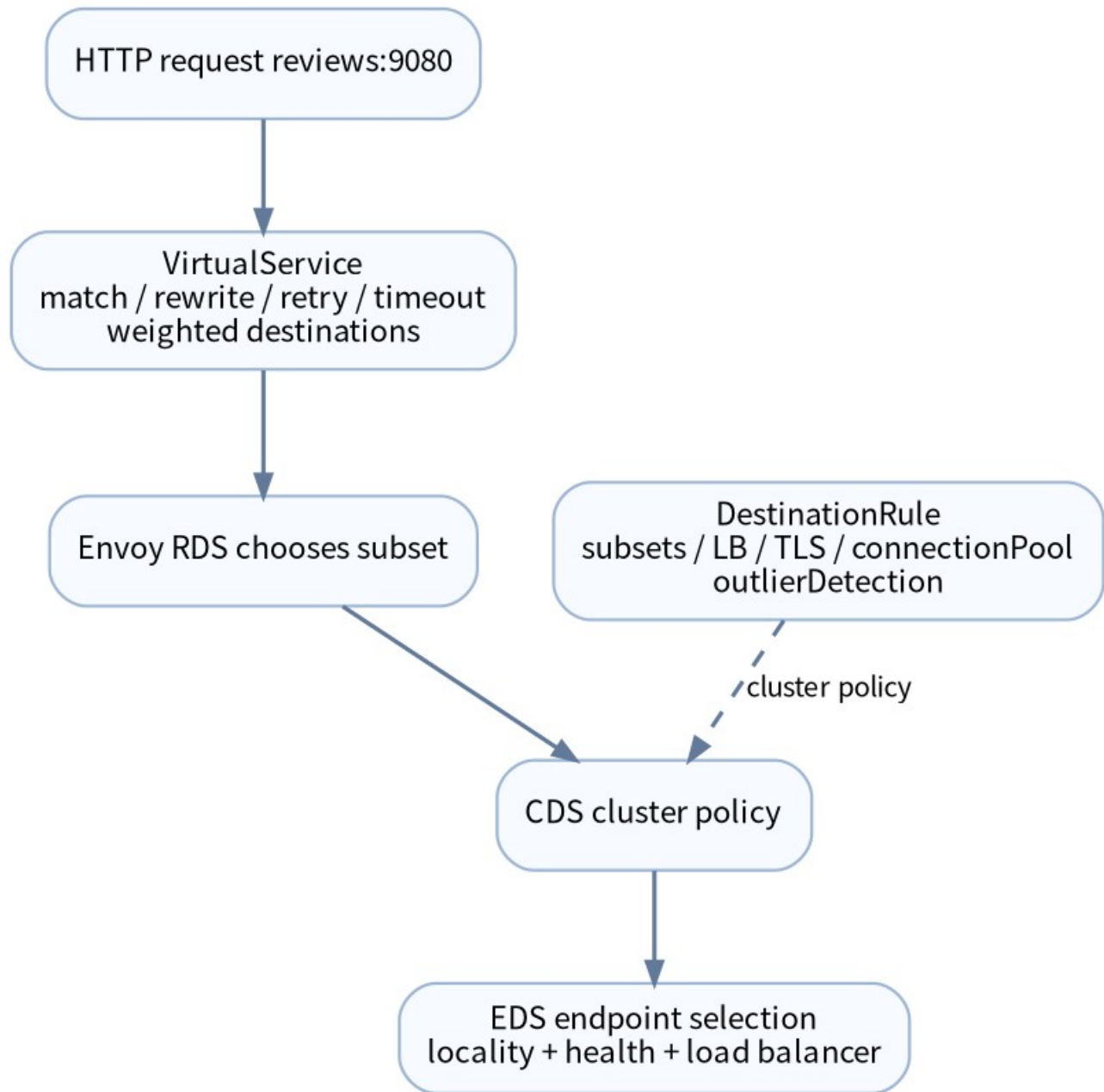


图 5: VirtualService 负责“路由选择”，DestinationRule 负责“目的地策略”

### 6.1 VirtualService

- hosts + gateways 定义规则作用域；mesh 表示 sidecar/waypoint mesh traffic。
- HTTP match 支持 URI/header/method/query/source labels 等条件；规则按顺序匹配。
- route 可按 weight 分流到不同 subset；也可 rewrite/redirect/mirror/fault。
- retries/timeout 是请求级策略，需要理解与应用自身 timeout、LB idle timeout 的叠加。

## 6.2 DestinationRule

- subset 通过 workload labels 对 endpoint 分组。
- trafficPolicy 包含 loadBalancer、connectionPool、outlierDetection、TLS、portLevelSettings。
- ISTIO\_MUTUAL 让 Envoy 使用 Istio 管理的 workload credentials；SIMPLE/MUTUAL/CREDENTIAL\_NAME 有不同语义。
- 配置目标 host 的解析和 namespace 作用域是大量“规则看起来存在但不生效”的根因。

## 6.3 Retry、Timeout、Circuit Breaking、Outlier Detection

| 机制                | 作用位置                     | 关键风险                         |
|-------------------|--------------------------|------------------------------|
| Timeout           | 单请求总时间预算                 | 多层 timeout 叠加导致意外早退          |
| Retry             | 失败后重新尝试                  | 放大下游压力；非幂等请求风险               |
| Connection Pool   | 连接/并发队列上限                | 阈值太低产生 UO/503                |
| Outlier Detection | 客户端侧剔除异常 endpoint        | 小规模实例易过度剔除                   |
| Locality LB       | 按 region/zone/subzone 分配 | 需要 endpoint locality 与网络拓扑正确 |

## 6.4 Weighted routing 的统计误区

90/10 并不意味着任意 10 个请求都精确 9/1；随机/加权 LB 的观测需要足够样本。长连接、HTTP/2 multiplexing、connection pooling 还会让请求分布与连接分布产生差异。

## 7. Gateway、Gateway API 与 Ingress/Egress

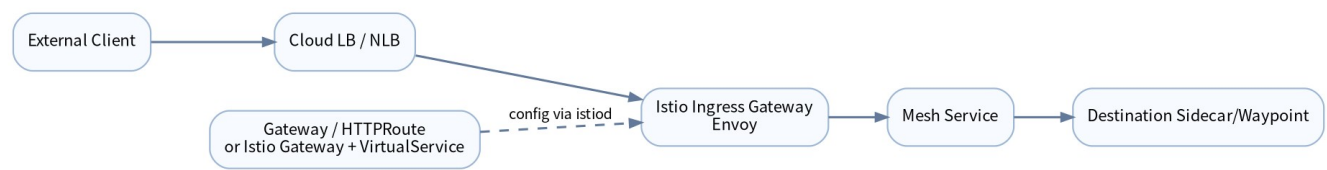


图 6: Ingress Gateway 的典型路径

### 7.1 Istio Gateway vs Kubernetes Gateway API

Istio 仍支持 networking.istio.io Gateway + VirtualService，同时对 Kubernetes Gateway API 的支持不断增强。面试需要能说明二者的 API 所有权、多租户模型、Route attachment 和 status 语义，而不是只会写 YAML。

### 7.2 Ingress Gateway 与 East-West Gateway 的区别

| 维度     | Ingress Gateway           | East-West Gateway                              |
|--------|---------------------------|------------------------------------------------|
| 主要流量   | 外部 -> mesh 服务             | cluster/network 间 mesh 流量                      |
| TLS 模式 | 终止 TLS / passthrough 均可   | 常见 AUTO_PASSTHROUGH + mTLS                     |
| 服务暴露   | 面向 north-south host/route | 面向 *.local / multicluster service reachability |
| 常见 LB  | L4/L7 均可能                 | 跨网络 AUTO_PASSTHROUGH 场景通常要求 L4 LB              |

### 7.3 Egress

ServiceEntry 将网格外服务显式加入 Istio registry；配合 VirtualService、DestinationRule 与 Egress Gateway 可以实现外部域名可见性、TLS origination、集中出口审计与策略。但若底层网络仍允许 Pod 直接访问公网，Egress Gateway 不是天然的强制安全边界，需要网络策略/防火墙配合。

## 8. Security : SPIFFE、mTLS、SDS、Authentication 与 Authorization



图 7: ServiceAccount -> SPIFFE identity -> SDS -> mTLS/AuthZ

### 8.1 Workload Identity

Istio 将 Kubernetes ServiceAccount 映射为工作负载身份，典型 SPIFFE URI 为 `spiffe://<trust-domain>/ns/<namespace>/sa/<service-account>`。证书本身是身份载体，不是“某个 Pod IP 的证书”。

### 8.2 PeerAuthentication / RequestAuthentication / AuthorizationPolicy

| 资源                    | 解决的问题        | 关键点                                              |
|-----------------------|--------------|--------------------------------------------------|
| PeerAuthentication    | 服务间 mTLS 模式  | STRICT/PERMISSIVE/DISABLE；作用域与端口级配置              |
| RequestAuthentication | 验证 JWT       | issuer、JWKS、多个 token 来源                          |
| AuthorizationPolicy   | 允许/拒绝哪些主体做什么 | DENY 优先；principal/namespace/method/path/port 等条件 |

### 8.3 TLS 常见失败模式

- CERTIFICATE\_VERIFY\_FAILED：root/trust domain/SAN/证书链/系统时间不一致。
- UPSTREAM\_TRANSPORT\_FAILURE\_REASON：客户端 sidecar 到上游 TLS handshake 失败。
- DestinationRule TLS 模式与服务端 PeerAuthentication 不匹配。
- 多集群自签 CA 不共享 root，导致跨集群 mTLS 失败。
- JWT audience / projected token 配置不符合 Istio CA 身份验证预期。

### 8.4 证书轮转与故障窗口

Envoy 不需要重启来更新 workload certificate；agent/SDS 会在证书生命周期内主动轮换。排障时应查看 proxy-config secret 的有效期、serial、root bundle，并结合 istiod CA 日志，而不是只重启 Pod。

## 9. Observability : Metrics、 Access Log、 Tracing 与 SLO

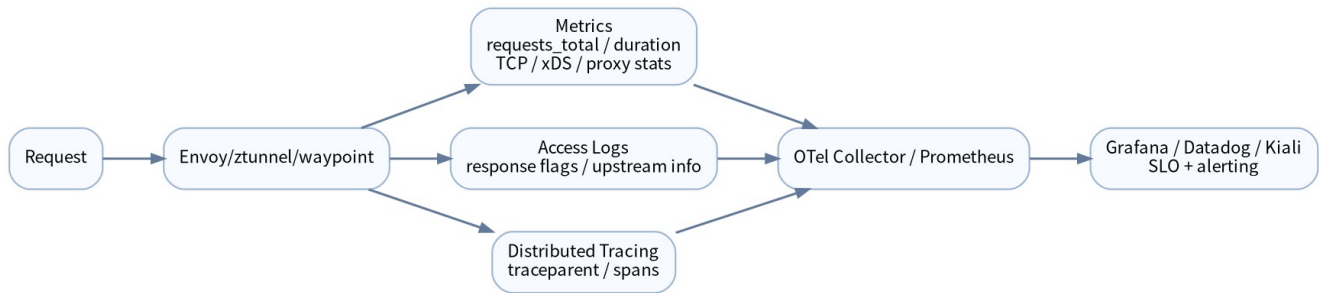


图 8: 从单个请求到多层遥测与 SLO

### 9.1 RED/USE 指标

- Request: requests\_total、 response\_code、 duration、 request/response bytes。
- Envoy: upstream\_cx\_\*、 upstream\_rq\_\*、 cluster membership、 outlier、 circuit breaker、 listener/worker stats。
- Control plane: xDS push time、 connected proxies、 pilot errors、 config rejection、 CPU/memory。
- Ambient: ztunnel connection/bytes/L4 telemetry; waypoint 提供 L7 指标。

### 9.2 Access Log response flags

| Flag | 常见含义                            | 第一验证方向                            |
|------|---------------------------------|-----------------------------------|
| NR   | No Route                        | RDS/VirtualHost/host/port/gateway |
| UH   | No Healthy Upstream             | EDS/health/outlier/subset         |
| UF   | Upstream Connection Failure     | 网络/TLS/upstream listen            |
| UC   | Upstream Connection Termination | 应用关闭/网络 reset                     |
| UT   | Upstream Request Timeout        | timeout/性能/拥塞                     |
| UO   | Upstream Overflow               | circuit breaker/connection pool   |

### 9.3 Tracing

Envoy 可以生成/传播 trace context，但应用通常仍需传播 header 才能形成完整跨服务 trace。面试中应区分“sidecar 自动采样”和“应用 span/上下文传播”；Service Mesh 并不能自动知道业务内部函数调用。

## 10. Performance 与 Scalability

### 10.1 数据平面开销来自哪里

代理开销主要来自每请求协议解析、TLS 加解密、filter chain、序列化/日志/遥测、连接管理，以及 sidecar 资源争用。要区分 P50 与 P99、短连接与长连接、HTTP/1.1 与 HTTP/2、small payload 与 streaming。

### 10.2 控制平面扩展性

- Proxy 数量越多，xDS stream、push fan-out、配置体积和内存压力越大。
- 过大的 Sidecar 可见性会让每个 proxy 收到大量无关 clusters/routes；Sidecar/DiscoverySelectors 可用于控制配置范围。
- Endpoint churn（大规模滚动发布/HPA）可能比静态 Service 数更考验推送路径。
- 多 revision、多 primary multicluster 会带来额外观测与操作复杂度。

### 10.3 容量规划要回答的问题

| 问题              | 指标/证据                                           |
|-----------------|-------------------------------------------------|
| 每个 proxy 配置多大？  | config dump 大小、cluster/listener 数、proxy memory  |
| push 是否积压？      | pilot push duration、debounce、queue、CPU          |
| sidecar 是否成为瓶颈？ | Envoy CPU、rq latency、cx stats、worker saturation |
| gateway 是否够用？   | RPS、active connections、TLS handshakes、p99、CPU   |
| 证书/CA 是否成为瓶颈？   | CSR QPS、latency、失败率、rotation burst              |

## 11. Multicluster / Multinetwork 深入

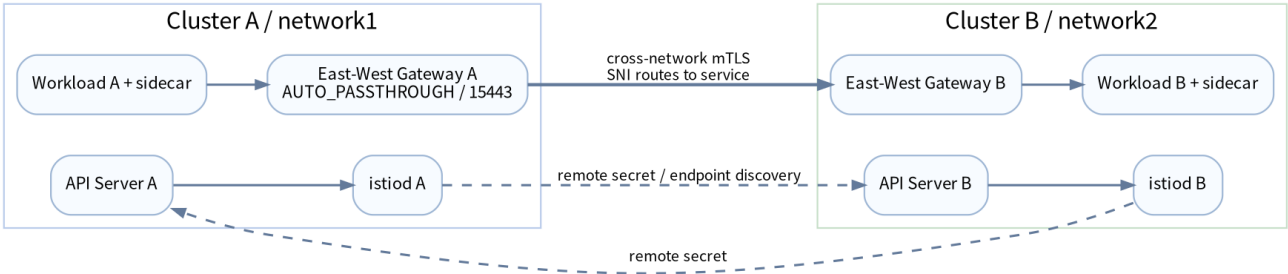


图 9: Multi-Primary + Multi-Network + East-West Gateway

### 11.1 三个维度一定要分开

| 维度      | 问题                          | 典型值                       |
|---------|-----------------------------|---------------------------|
| Mesh    | 是否属于同一 mesh / trust domain? | meshID                    |
| Cluster | 工作负载在哪个 Kubernetes cluster? | clusterName               |
| Network | Pod IP 是否能直接跨边界路由?          | topology.istio.io/network |

### 11.2 Multi-Primary vs Primary-Remote

Multi-Primary 每个 primary 都运行 control plane 并观察多个集群；Primary-Remote 把 remote workload 的控制平面依赖集中到 primary。前者故障域更独立但资源和操作成本更高；后者控制面更集中，跨网络 control-plane reachability 更关键。

### 11.3 Remote Secret 的本质

remote secret 不是“让业务流量跨集群”的密钥，而是给远端 istiod 提供访问另一个 Kubernetes API Server 的凭证，从而发现 Service/Endpoint 等对象。业务跨网络数据流量通常仍通过 east-west gateway。

### 11.4 East-West Gateway 与 AUTO\_PASSTHROUGH

对于不同网络，源 sidecar 将远端服务 endpoint 抽象到 network gateway；east-west gateway 基于 SNI/服务身份将流量转交到目标网络。使用会终止 TLS 的 L7 LB 破坏 AUTO\_PASSTHROUGH 语义，官方明确警告这可能引发 mTLS 握手失败和 503。

### 11.5 多集群常见事故树

- istiod 看不到远端 endpoint：remote secret、RBAC、API endpoint/CA、网络访问。
- proxy 看得到远端 endpoint 但访问失败：east-west LB、防火墙、15443、network label、TLS root。
- 单向可达：两个方向的 remote secret、gateway 暴露、安全组或 service exposure 不对称。
- subset 流量全进 other：版本 label/subset 与两个集群 endpoint 元数据不一致。

## 12. Ambient Mesh : ztunnel、HBONE、Waypoint

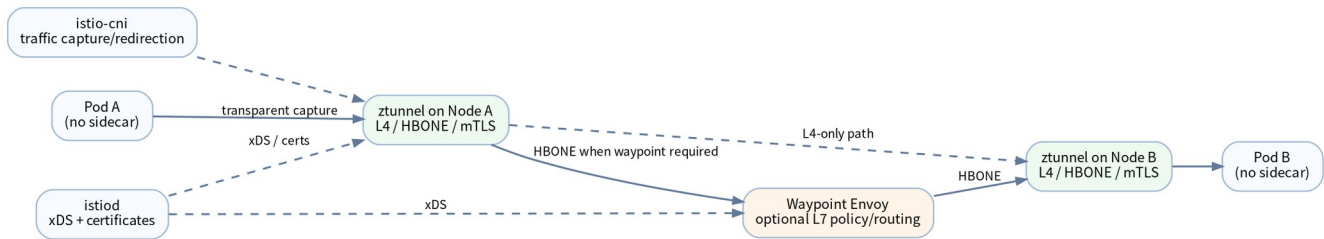


图 10: Ambient L4 secure overlay 与可选 L7 waypoint

### 12.1 ztunnel

ztunnel 是每 Node 的 purpose-built L4 proxy，使用 Rust 实现。它负责 transparent capture、mTLS、身份认证、L4 Authorization 与 telemetry，并通过 HBONE（基于 HTTP CONNECT 的隧道协议）在 mesh 节点之间承载安全流量。它不会解析 workload HTTP headers。

### 12.2 Waypoint

当需要 HTTP routing、retry、timeout、L7 AuthZ、HTTP metrics/access log/tracing 等能力时，引入 waypoint Envoy。Ambient 的 waypoint 更接近“目标资源的代理”，策略通常由目标侧 waypoint 强制执行。

### 12.3 Sidecar 与 Ambient 共存

同一 mesh 可以同时存在 sidecar workload 与 ambient workload，迁移可以按 namespace/workload 分阶段进行。真正的迁移难点不是打 label，而是验证功能等价性：已有 EnvoyFilter、Sidecar resource、某些扩展/遥测、L7 策略是否在 waypoint 模型下有等价实现。

### 12.4 Ambient Multicluster

截至 2026 当前官方文档，Ambient 跨不同网络的 multicluster 安装以 multi-primary 为支持模型，并通过 ambient east-west gateway、remote secrets 和 Gateway API 相关组件完成跨网络服务可达。

## 13. Installation、 Revision、 Upgrade 与 Rollback

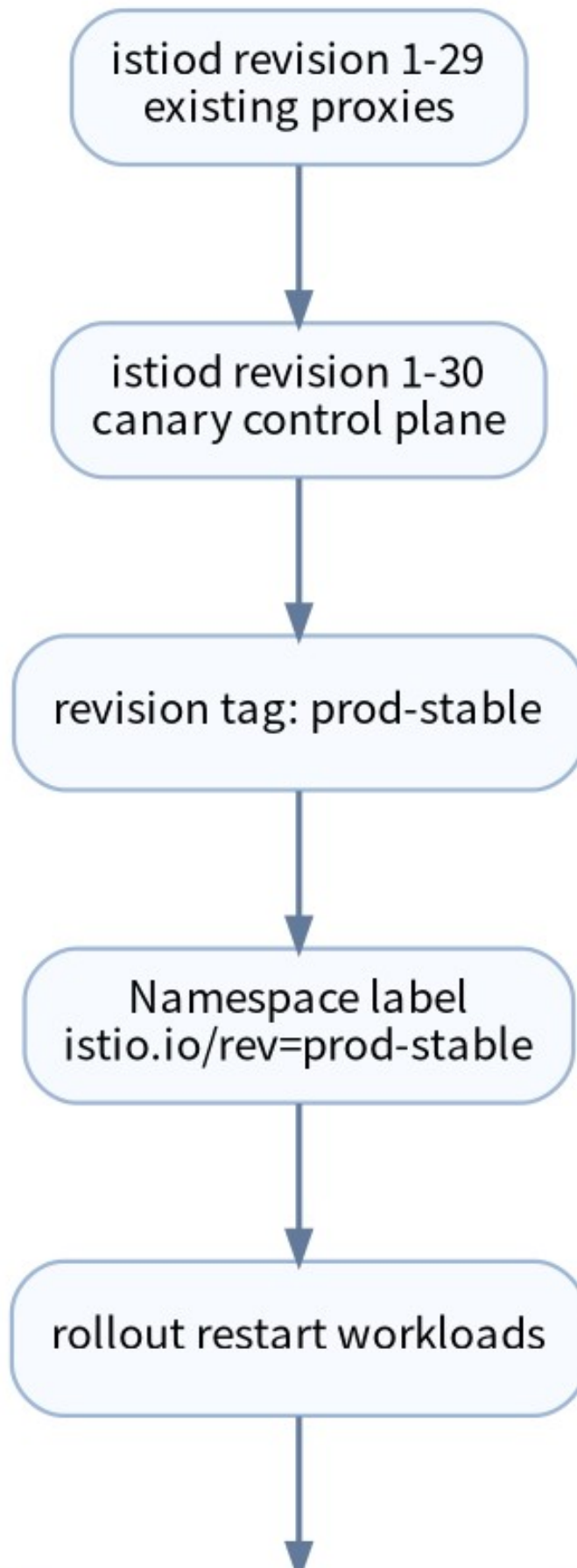


图 11: Canary revision 升级与回滚

### 13.1 Revision 模型

控制平面 revision 允许新旧 istiod 并行。namespace/pod 通过 istio.io/rev 或 revision tag 选择注入与控制平面。升级时推荐先安装新 revision、验证、逐 namespace/workload rollout，再下线旧 revision。

### 13.2 升级检查清单

- 确认 Istio 与 Kubernetes 支持矩阵；检查弃用 API 与 change notes。
- 运行 istioctl analyze；确认 CRD/base 兼容。
- 先升级 control plane，再滚动 data plane；避免无计划全量 proxy restart。
- 检查 gateway、CNI、ztunnel/waypoint 与 control plane revision 一致性。
- 制定 rollback：revision tag/namespace label 回切、workload restart、Gateway 回滚。

### 13.3 Helm / GitOps 境的

base/istiod/gateway/CNI 往往由不同 HelmRelease/Terraform/Flux 对象管理，版本和 values 漂移会造成端口、revision、CA 或 feature gate 不一致。生产升级前需要生成“实际 values 差异 + CRD 兼容 + 数据平面重启范围”的变更计划。

## 14. Troubleshooting : 从症状到证据

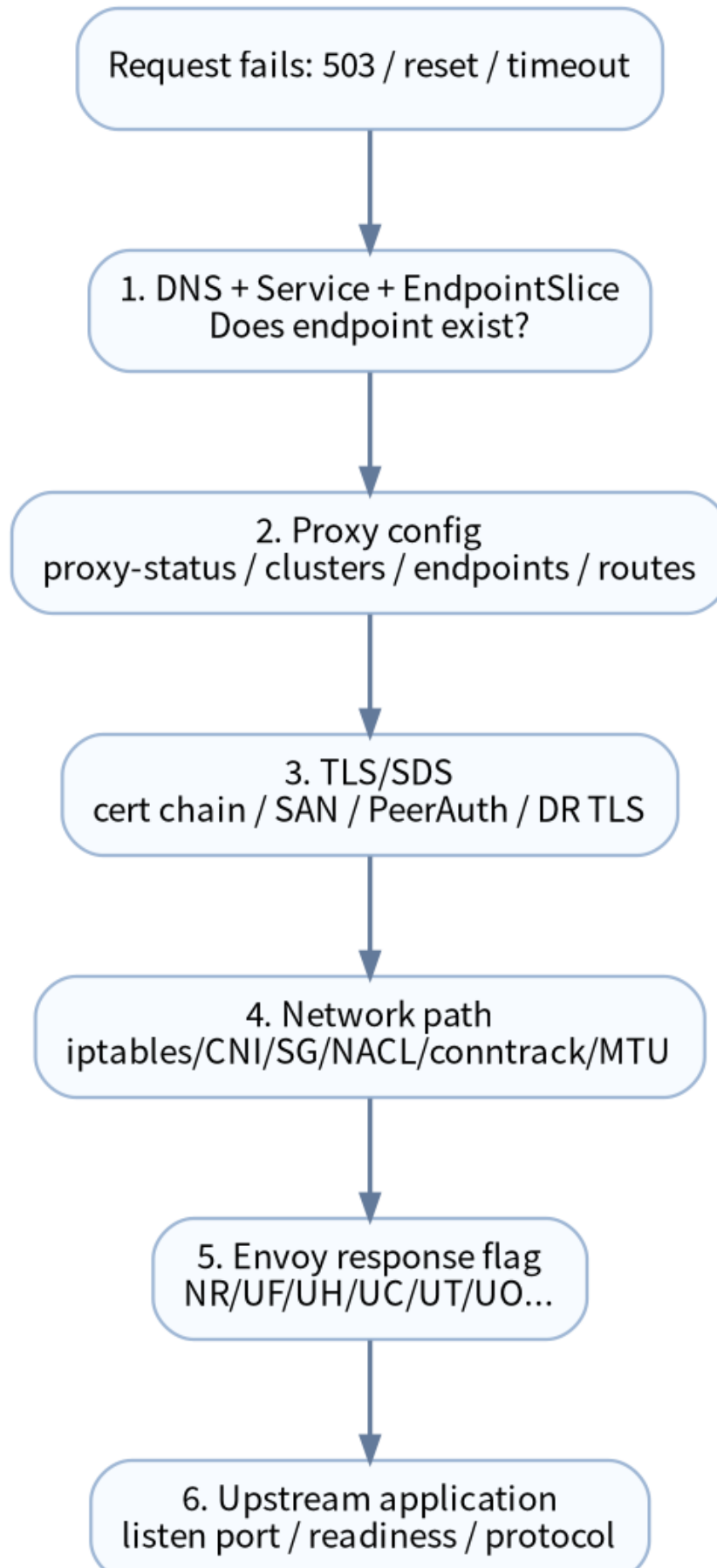


图 12: 503/reset/timeout 的分层排障路径

## 14.1 黄金排障顺序

1. 先确认不经过 mesh 时间问题是否存在：应用监听、readiness、Service/EndpointSlice。
2. 检查控制面一致性：istioctl proxy-status / analyze。
3. 检查目标 proxy 的 LDS/RDS/CDS/EDS 是否符合预期。
4. 检查 SDS secret、PeerAuthentication、DestinationRule TLS。
5. 检查 Linux/K8s 网络：iptables/CNI、DNS、MTU、conntrack、SG/NACL/LB。
6. 最后才考虑“重启能不能解决”；重启不是诊断。

## 14.2 命令速查

```
istioctl proxy-status
istioctl analyze -A
istioctl proxy-config listeners POD -n NS
istioctl proxy-config routes POD -n NS
istioctl proxy-config clusters POD -n NS
istioctl proxy-config endpoints POD -n NS
istioctl proxy-config secret POD -n NS
istioctl proxy-config log POD -n NS
kubectl get svc,endpointslice,pod -A -o wide
kubectl exec POD -c istio-proxy -- curl -s localhost:15000/config_dump
```

## 14.3 典型场景 1：503 NR

先看 access log 的 route\_name/authority/upstream\_cluster；NR 通常说明没有匹配 route。检查请求 Host/port 与 VirtualService hosts/gateways、RDS virtual host domain、Gateway attachment。

## 14.4 典型场景 2：503 UH

UH 指没有健康 upstream。检查 EDS endpoint 是否存在、subset labels 是否匹配、outlier detection 是否剔除了所有实例、EndpointSlice readiness 是否为 false。

## 14.5 典型场景 3：跨集群 TLS\_error

按“remote endpoint 是否被发现 -> network gateway 是否正确 -> 15443 是否可达 -> SNI/AutoPassthrough -> root CA/trust domain -> workload SAN/identity”顺序验证，避免一上来就重签所有证书。

## 15. Istio 源码阅读地图

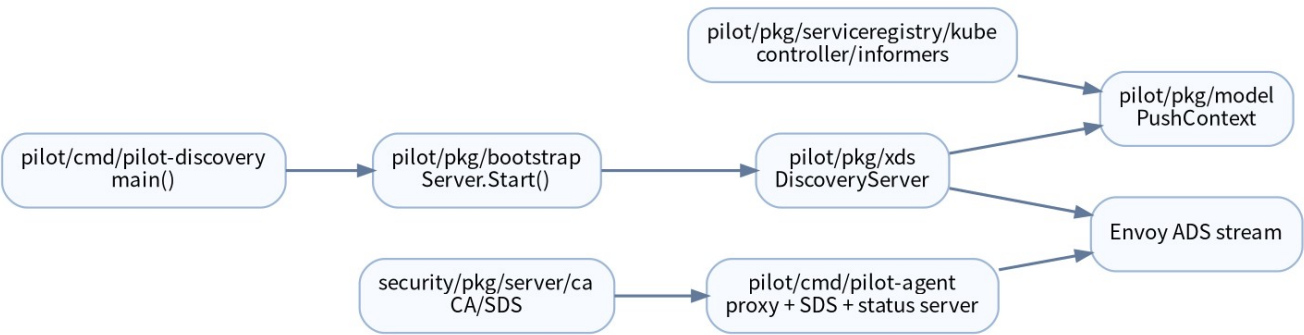


图 13: Pilot/agent/registry/security 的源码阅读主线

### 15.1 推荐从这些目录开始

| 主题                 | 源码方向                                           | 要回答的问题                                          |
|--------------------|------------------------------------------------|-------------------------------------------------|
| pilot-discovery 启动 | pilot/cmd/pilot-discovery, pilot/pkg/bootstrap | istiod 启动了哪些 server/controller?                 |
| K8s registry       | pilot/pkg/serviceregistry/kube                 | Service/EndpointSlice 如何变为 internal model?      |
| xDS                | pilot/pkg/xds                                  | proxy 如何建立 ADS stream、push 如何触发?                |
| model              | pilot/pkg/model                                | PushContext/Proxy/Service/ServiceInstance 表示什么? |
| agent              | pilot/cmd/pilot-agent, pkg/istio-agent         | Envoy bootstrap/SDS/进程管理如何做?                    |
| security           | security/pkg/server/ca                         | CSR 如何验证并签发证书?                                  |
| injection          | pkg/kube/inject 等                              | PodSpec patch 如何生成?                             |

### 15.2 一条完整源码追踪题

题目：创建一个新的 DestinationRule 后，某个 sidecar 最终收到新的 cluster policy，中间发生什么？

7. Kubernetes informer/ConfigStore 捕获 CRD update。
8. 事件进入 config change 处理，计算受影响服务/namespace/proxy。
9. PushContext 更新或复用相关模型，并进入 debounced push。
10. DiscoveryServer 对已连接 proxy 根据类型生成 CDS/EDS/RDS/LDS 等资源。
11. 通过 ADS stream 下发新 version/nonce。
12. Envoy 验证配置并 ACK；NACK 时控制面记录 error，旧可用配置通常保持。
13. 数据面新的请求按更新后的 cluster policy 执行。

## 16. Envoy / Istio 配置翻译练习

### 16.1 从 YAML 推导 xDS

```
apiVersion: networking.istio.io/v1
kind: VirtualService
metadata:
  name: reviews
spec:
  hosts: [reviews.default.svc.cluster.local]
  http:
  - route:
    - destination: {host: reviews.default.svc.cluster.local, subset: v1}
      weight: 90
    - destination: {host: reviews.default.svc.cluster.local, subset: v2}
      weight: 10
```

需要能推导：RDS 中出现目标 host 的 VirtualHost/route；route 指向两个 weighted clusters；CDS 中存在 outbound|port|v1|host 与 v2 cluster；EDS 为每个 subset cluster 提供 label 匹配后的 endpoint。

### 16.2 配置不生效的五类根因

- 作用域：规则 namespace、exportTo、Sidecar egress hosts、Gateway attachment。
- 主机名：短名按规则所在 namespace 解析，不一定是 service 所在 namespace。
- 端口/协议：Service port name 或 protocol sniffing 导致 HTTP/TCP 语义不同。
- subset：DestinationRule 不存在或 label 与 workload 不匹配。
- 控制面同步：proxy 连错 revision、xDS stale/NACK、配置未推到该 proxy。

## 17. 高 : DNS、Protocol Sniffing、HTTP/2、gRPC、TCP

### 17.1 Protocol detection

Istio 依赖 Service port name/appProtocol 与协议检测来决定生成 HTTP 还是 TCP filter。错误的端口命名会导致高级 HTTP 路由、metrics 或 retry 不生效，甚至出现连接失败。

### 17.2 HTTP/2 与 gRPC

- HTTP/2 multiplexing 使“连接数”不再等价于“并发请求数”。
- gRPC deadline 与 Envoy timeout/retry 交互时需要明确谁的时间预算更短。
- 长流/streaming 请求对 drain、idle timeout、outlier 和 rollout 有特殊影响。
- Gateway TLS ALPN 与 h2 协商失败会造成 gRPC 看似网络正常但应用不可用。

### 17.3 DNS capture

Sidecar/ambient 均可能涉及 DNS capture/auto allocation 等机制。排障时区分“应用解析到了什么 IP”与“Envoy 最终依据 service registry 选择了什么 cluster/endpoint”，尤其是 ServiceEntry 和外部服务场景。

## 18. 高级安全专题：Trust Domain、CA、External CA 与多集群

### 18.1 Root / Intermediate CA

生产 mesh 常用离线 root + 每集群/环境 intermediate CA。Istio workload cert chain 是否互信取决于 root bundle 和 trust domain/alias 等配置，而不只是“两个集群都叫 istio-ca-secret”。

### 18.2 Trust Domain Migration

改变 trust domain 会改变 SPIFFE principal。迁移时需要考虑 AuthorizationPolicy 中显式 principal、跨集群身份、旧证书与新证书的过渡、trustDomainAliases。

### 18.3 External CA / cert-manager / Vault

面试重点是职责边界：谁验证 workload identity、谁签 CSR、root 私钥放在哪里、证书 TTL/rotation 怎么做、CA 故障时 data plane 有多长可用窗口，而不是只说“可以接 Vault”。

## 19. Sidecar -> Ambient 迁移设计

### 19.1 迁移前资产盘点

| 资产                             | 为什么要盘点                               |
|--------------------------------|--------------------------------------|
| VirtualService/DestinationRule | 确认 waypoint 支持/行为差异                  |
| EnvoyFilter/WasmPlugin         | 最容易出现功能等价性问题                         |
| Sidecar resource               | ambient 可见性与出站控制模型不同                 |
| PeerAuth/AuthZ                 | L4 与 L7 enforcement point 变化         |
| Telemetry/AccessLog            | ztunnel 与 waypoint 的遥测维度不同           |
| Multicluster                   | ambient 当前拓扑支持与 east-west gateway 不同 |

### 19.2 推荐迁移策略

- 14. 选择低风险 namespace，建立 sidecar baseline：成功率、p99、CPU、memory、xDS config size。
- 15. 启用 ambient L4，仅 ztunnel；验证 mTLS、L4 policy、DNS、长连接。
- 16. 需要 L7 的 namespace/workload 创建 waypoint；验证 routing/retry/AuthZ/telemetry。
- 17. 灰度扩大范围，并保留快速回退到 sidecar 的 revision/label 操作手册。

## 20. AI Gateway 与 Istio 1.30 的新方向

Istio 1.30 引入实验性的 agentgateway GatewayClass，可在 Gateway API gateway 场景中用面向 AI agent/MCP 流量的新数据平面替代 Envoy。当前属于 early access，不应把它等同于 sidecar 或 waypoint 的替代。

### 20.1 为什么 Service Mesh 面试开始出现 AI Gateway

- MCP/agent tool traffic 需要 identity、policy、routing、telemetry 与 secret 边界。
- LLM/Agent 流量可能是长连接、streaming、token 级 observability，传统 HTTP API gateway 指标不完全够。
- 平台团队希望复用 Kubernetes Gateway API 与 service mesh 控制面，而不是再维护一套独立入口栈。

**面试回答边界** 可以介绍 1.30 的 agentgateway，但要明确其 Gateway API-only、experimental/early access 属性；不要把尚未稳定的能力当作生产默认方案。

## 21. System Design : 设计一个生产级 Istio Mesh

### 21.1 场景：5000 Nodes / 100k Pods / 多租户 / Multi-Region

- 18. 确定故障域：region/cluster/network/control-plane topology；优先让区域内控制面独立。
- 19. 控制配置范围：namespace tenancy、Sidecar/DiscoverySelectors、Gateway ownership、exportTo。
- 20. 数据平面选择：sidecar、ambient 或混合；以 L7 功能需求与资源成本决定。
- 21. 安全：共享 root、intermediate CA、trust domain、STRICT mTLS、AuthZ ownership。
- 22. 多集群：multi-primary + network gateways；API server endpoint 与 remote secret 生命周期。
- 23. 容量：istiod replicas、gateway replicas、PDB、anti-affinity、xDS push SLO。
- 24. 升级：revision canary + proxy rollout budget + rollback。
- 25. 可观测性：mesh SLO、proxy/control plane metrics、access log sampling、trace budget。

### 21.2 必主的 trade-off

| 决策                    | 收益            | 代价                              |
|-----------------------|---------------|---------------------------------|
| 每 Pod sidecar         | 完整 L7、故障隔离直观  | 资源开销、升级与生命周期耦合                  |
| Ambient L4 + waypoint | 代理数减少、分层启用 L7 | 新数据路径、waypoint ownership/功能差异   |
| Multi-primary         | 控制面故障域更小      | 运维/成本更高                         |
| Primary-remote        | 集中控制          | 对 primary 与跨网 control path 依赖更强 |
| 全量 access log         | 故障证据丰富        | CPU/IO/存储/隐私成本高                 |

## 22. 120 道 Istio 高频面试题与追问树

### 1. [架构] Istio control plane 和 data plane 的边界是什么？

2 分钟回答：先定义 istiod 不在请求同步路径；再说明配置/证书下发；最后讨论 istiod 宕机窗口。

10 分钟深入：从 Kubernetes 事件、istiod 内部模型、xDS stream、Envoy config 与请求数据路径分别解释职责边界；最后讨论控制面故障不会立即停止已有数据面，但会影响配置变化、证书轮转和新 workload。

验证命令：istioctl proxy-status；istioctl pc listeners/clusters POD；查看 istiod discovery/ADS 日志。

常见误判：把 istiod 当成请求转发代理，或者认为 istiod 宕机后所有业务立即中断。

Trade-off：控制平面副本数、隔离故障域、配置可见性与操作复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 2. [架构] istiod 由哪些逻辑模块组成？

2 分钟回答：服务发现、config store、xDS、CA、webhook；强调历史组件已经合并。

10 分钟深入：从 Kubernetes 事件、istiod 内部模型、xDS stream、Envoy config 与请求数据路径分别解释职责边界；最后讨论控制面故障不会立即停止已有数据面，但会影响配置变化、证书轮转和新 workload。

验证命令：istioctl proxy-status；istioctl pc listeners/clusters POD；查看 istiod discovery/ADS 日志。

常见误判：把 istiod 当成请求转发代理，或者认为 istiod 宕机后所有业务立即中断。

Trade-off：控制平面副本数、隔离故障域、配置可见性与操作复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 3. [架构] pilot-agent 和 Envoy 的关系是什么？

2 分钟回答：agent 管 Envoy lifecycle/bootstrap/SDS，Envoy 实际转发流量。

10 分钟深入：从 Kubernetes 事件、istiod 内部模型、xDS stream、Envoy config 与请求数据路径分别解释职责边界；最后讨论控制面故障不会立即停止已有数据面，但会影响配置变化、证书轮转和新 workload。

验证命令：istioctl proxy-status；istioctl pc listeners/clusters POD；查看 istiod discovery/ADS 日志。

常见误判：把 istiod 当成请求转发代理，或者认为 istiod 宕机后所有业务立即中断。

Trade-off：控制平面副本数、隔离故障域、配置可见性与操作复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 4. [注入] sidecar 注入发生在哪个阶段？

2 分钟回答：kube-apiserver admission -> mutating webhook -> PodSpec patch。

10 分钟深入：按 kube-apiserver Admission -> injector webhook -> patch PodSpec -> kubelet/CRI -> pilot-agent -> Envoy bootstrap/xDS/SDS 顺序回答，并说明 revision 与 CNI 的参与点。

验证命令：kubectrl get mutatingwebhookconfiguration；kubectrl get pod -o yaml；kubectrl logs -c istio-proxy；istioctl proxy-status。

常见误判：看到 istio-proxy 容器存在就认为注入和流量劫持一定正确。

Trade-off：Webhook failurePolicy、CNI 与 initContainer、安全权限、升级耦合。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 5. [注入] 为什么用 Istio CNI？

2 分钟回答：避免应用 Pod 需要 NET\_ADMIN，把流量重定向下沉到节点 CNI。

10 分钟深入：按 kube-apiserver Admission -> injector webhook -> patch PodSpec -> kubelet/CRI -> pilot-agent -> Envoy bootstrap/xDS/SDS 顺序回答，并说明 revision 与 CNI 的参与点。

验证命令：kubectrl get mutatingwebhookconfiguration；kubectrl get pod -o yaml；kubectrl logs -c istio-proxy；istioctl proxy-status。

常见误判：看到 istio-proxy 容器存在就认为注入和流量劫持一定正确。

Trade-off：Webhook failurePolicy、CNI 与 initContainer、安全权限、升级耦合。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 6. [网络] 15001 和 15006 分别是什么？

2 分钟回答：outbound/inbound capture；结合 iptables 链路讲。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 7. [xDS] LDS/CDS/RDS/EDS 分别控制什么？

2 分钟回答：Listener/Cluster/Route/Endpoint，并能串成请求路径。

10 分钟深入：从配置或 EndpointSlice 事件进入 Pilot model，经过 PushContext/debounce/affected-proxy 计算，生成 LDS/RDS/CDS/EDS 并通过 ADS 下发，Envoy ACK/NACK。

验证命令：istioctl proxy-status；istioctl pc all POD；Envoy /config\_dump；istiod 日志搜索 NACK/version/nonce。

常见误判：把 xDS 看成每次都全量重建全部代理配置。

Trade-off：推送实时性与 debounce/CPU 之间的平衡，配置作用域与可操作性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 8. [xDS] 什么是 ADS？

2 分钟回答：同一 gRPC stream 聚合发现，利于依赖和版本管理。

10 分钟深入：从配置或 EndpointSlice 事件进入 Pilot model，经过 PushContext/debounce/affected-proxy 计算，生成 LDS/RDS/CDS/EDS 并通过 ADS 下发，Envoy ACK/NACK。

验证命令：istioctl proxy-status；istioctl pc all POD；Envoy /config\_dump；istiod 日志搜索 NACK/version/nonce。

常见误判：把 xDS 看成每次都全量重建全部代理配置。

Trade-off：推送实时性与 debounce/CPU 之间的平衡，配置作用域与可操作性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 9. [xDS] Envoy NACK 配置后会发生什么？

2 分钟回答：报告错误；通常继续保持最近一次可用配置；定位 nonce/version。

10 分钟深入：从配置或 EndpointSlice 事件进入 Pilot model，经过 PushContext/debounce/affected-proxy 计算，生成 LDS/RDS/CDS/EDS 并通过 ADS 下发，Envoy ACK/NACK。

验证命令：istioctl proxy-status；istioctl pc all POD；Envoy /config\_dump；istiod 日志搜索 NACK/version/nonce。

常见误判：把 xDS 看成每次都全量重建全部代理配置。

Trade-off：推送实时性与 debounce/CPU 之间的平衡，配置作用域与可操作性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 10. [路由] VirtualService 与 DestinationRule 区别？

2 分钟回答：VS 选择去哪里，DR 定义到目的地以后怎么连接/负载均衡/TLS。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 11. [路由] subset 不生效的常见原因？

2 分钟回答：DR 不可见、labels 不匹配、host/namespace 错、proxy config stale。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 12. [路由] 90/10 为什么 10 次请求不一定 9/1？

2 分钟回答：统计采样、连接复用、LB 随机性。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 13. [可靠性] retry 为什么可能让事故更严重？

2 分钟回答：retry storm、非幂等、下游饱和；预算/退避/重试条件。

10 分钟深入：从请求预算、连接池、熔断、异常实例剔除、retry amplification 和 failure domain 解释如何避免级联故障。

验证命令：Envoy cluster stats；access log flags；istioctl pc cluster；负载测试。

常见误判：认为 retry 越多越可靠、outlier detection 等于服务端健康检查。

Trade-off：快速失败与可用性、激进剔除与容量损失、重试收益与下游放大。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 14. [可靠性] outlier detection 与 circuit breaker 有什么不同？

2 分钟回答：前者剔除异常 endpoint，后者限制本地连接/请求资源。

10 分钟深入：从请求预算、连接池、熔断、异常实例剔除、retry amplification 和 failure domain 解释如何避免级联故障。

验证命令：Envoy cluster stats；access log flags；istioctl pc cluster；负载测试。

常见误判：认为 retry 越多越可靠、outlier detection 等于服务端健康检查。

Trade-off：快速失败与可用性、激进剔除与容量损失、重试收益与下游放大。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**15. [安全] Istio workload identity 怎么来的？**

2 分钟回答：K8s SA -> token -> CA -> SPIFFE X.509 -> SDS。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**16. [安全] STRICT mTLS 为什么还可能连不上？**

2 分钟回答：DR TLS 模式、CA、SAN、network、证书有效期。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**17. [安全] PeerAuthentication 和 AuthorizationPolicy 区别？**

2 分钟回答：前者 transport auth mode，后者 request/connection authorization。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**18. [安全] RequestAuthentication 做什么？**

2 分钟回答：JWT validation；通常与 AuthZ 组合。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 19. [多集群] remote secret 的作用是什么？

2 分钟回答：istiod 跨集群访问 API server 做服务/endpoint discovery，不承载业务流量。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 20. [多集群] 为什么不同网络需要 east-west gateway？

2 分钟回答：Pod CIDR 不可直达，用 network gateway 承载跨网 mTLS。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 21. [多集群] 为什么 L7 LB 不适合 AUTO\_PASSTHROUGH？

2 分钟回答：会终止/改变 TLS，破坏基于 SNI 的 passthrough 与 workload mTLS。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 22. [多集群] meshID、clusterName、network 分别是什么？

2 分钟回答：身份/管理域、集群来源、网络可达域。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 23. [ambient] ztunnel 做什么？

2 分钟回答：per-node L4 secure overlay：capture、mTLS、L4 authz、telemetry、HBONE。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 24. [ambient] 什么时候需要 waypoint？

2 分钟回答：HTTP routing/retry/timeout/L7 AuthZ/HTTP telemetry 等 L7 能力。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 25. [ambient] Ambient 是不是没有 Envoy？

2 分钟回答：ztunnel 不是 Envoy；waypoint 仍是 Envoy；sidecar workload 可共存。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 26. [ambient] HBONE 是什么？

2 分钟回答：基于 HTTP CONNECT 的安全 tunneling protocol，用于 ambient transport。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectrl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 27. [运维] 如何做 Istio canary upgrade？

2 分钟回答：新 revision -> tag/namespace -> rollout -> verify -> remove old；可回退。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectrl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 28. [运维] istiod 宕机有什么影响？

2 分钟回答：已有 Envoy 保留 last config；新 Pod/xDS/证书轮转/变更受影响。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectrl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 29. [观测] 503 NR/UH/UF/UO 怎么区分？

2 分钟回答：route/healthy upstream/connect failure/overflow，各自映射不同排障层。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 30. [观测] 为什么 tracing 不可能完全无侵入？

2 分钟回答：mesh 可生成/采样 span，但业务跨线程/内部调用和 header 传播仍需应用协作。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 31. [性能] 如何降低 istiod xDS 压力？

2 分钟回答：缩小配置可见性、减少无关 push、合理 HPA/replica、避免巨大 CRDs/endpoint churn。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 32. [性能] sidecar CPU 高怎么排？

2 分钟回答：协议、TLS、日志、filter、流量量级、worker/连接、telemetry；对比 no-mesh baseline。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**33. [源码] DestinationRule 更新如何到 Envoy ?**

2 分钟回答: Informer/config event -> push context/debounce -> generate CDS -> ADS -> ACK。

10 分钟深入: 明确入口目录和对象: pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA, 并从事件追踪到 ADS ACK。

验证方法: 结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判: 背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off: 源码细节会随版本变化, 面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

**34. [源码] EndpointSlice update 影响哪个 xDS ?**

2 分钟回答: 主要 EDS, 但实际 push scope/其他资源依赖需结合实现与配置。

10 分钟深入: 明确入口目录和对象: pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA, 并从事件追踪到 ADS ACK。

验证方法: 结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判: 背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off: 源码细节会随版本变化, 面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

**35. [Gateway] Gateway API 与 Istio Gateway 的主要差异 ?**

2 分钟回答: K8s 标准 API、多角色 ownership/attachment/status vs Istio 自有 API。

10 分钟深入: 区分 cloud LB、Gateway resource、GatewayClass/controller、Envoy gateway pod、HTTPRoute/VirtualService 与后端 mesh service。

验证命令: kubectl describe gateway/httproute; istioctl pc routes GATEWAY\_POD; 查看 status conditions。

常见误判: 把 Kubernetes Gateway API 对象与实际 L4/L7 cloud load balancer 当成同一层。

Trade-off: 标准 Gateway API 提升跨实现可移植性, 但高级 Istio 特性仍需关注支持矩阵。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

**36. [Gateway] Ingress Gateway 是不是必须 ?**

2 分钟回答: mesh 内服务间通信不需要 ingress; 只在 north-south 暴露时需要。

10 分钟深入: 区分 cloud LB、Gateway resource、GatewayClass/controller、Envoy gateway pod、HTTPRoute/VirtualService 与后端 mesh service。

验证命令: kubectl describe gateway/httproute; istioctl pc routes GATEWAY\_POD; 查看 status conditions。

常见误判: 把 Kubernetes Gateway API 对象与实际 L4/L7 cloud load balancer 当成同一层。

Trade-off: 标准 Gateway API 提升跨实现可移植性, 但高级 Istio 特性仍需关注支持矩阵。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 37. [Egress] ServiceEntry 是网络 ACL 吗？

2 分钟回答：不是强制网络 ACL；需配合 outboundTrafficPolicy / gateway / NetworkPolicy/防火墙。

10 分钟深入：ServiceEntry 进入 service registry，VS/DR 控制路由/TLS，Egress Gateway 作为集中出口；若底层网络不封锁，应用可能绕过 gateway。

验证命令：istioctl pc cluster/route；检查 outboundTrafficPolicy；NetworkPolicy/SG/Firewall；egress gateway access log。

常见误判：以为创建 ServiceEntry 就自动形成安全白名单。

Trade-off：集中治理与单点容量/复杂度；强制出口需要 mesh 与底层网络策略共同实现。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 38. [TLS] SIMPLE/MUTUAL/ISTIO\_MUTUAL 有什么区别？

2 分钟回答：服务端单向、显式客户端证书双向、Istio SDS 管理的 mTLS。

10 分钟深入：区分 downstream TLS、upstream TLS、Gateway termination/passthrough、workload mTLS，并解释 SAN/root/ISTIO\_MUTUAL/PeerAuthentication 不匹配。

验证命令：istioctl pc secret/cluster；openssl s\_client；Envoy access log transport failure reason。

常见误判：看到 CERTIFICATE\_VERIFY\_FAILED 就直接重签 CA，而不先确认是哪一段 TLS。

Trade-off：证书生命周期、安全边界与可操作性的权衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 39. [网络] sidecar 注入后 DNS 正常但连接超时怎么查？

2 分钟回答：proxy route/cluster/endpoint -> TLS -> iptables/CNI -> network path。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 40. [网络] 为什么 ping 正常不代表 Istio 流量正常？

2 分钟回答：ICMP 不经过同样的 L4/L7/TLS/port/gateway 路径。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 41. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 42. [路由] Mirror 流量会不会影响主请求响应？

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 43. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**44. [安全] 如何验证一个 Pod 当前拿到的证书？**

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**45. [安全] 如何设计跨集群 CA？**

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**46. [运维] 为什么 Helm values 漂移很危险？**

2 分钟回答：base/istiod/gateway/CNI 独立生命周期导致 revision/ports/feature gates 不一致。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**47. [观测] 如何知道 endpoint 在远端 cluster？**

2 分钟回答：proxy-config endpoints 的 locality/network/metadata + istiod registry。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 48. [多集群] 跨集群只单向可达怎么查？

2 分钟回答：两个方向 remote secret/API access/gateway/SG/route/CA 对称性。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 49. [ambient] Ambient 中 L7 policy enforcement 在哪里？

2 分钟回答：destination waypoint；ztunnel 只做 L4。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 50. [ambient] 为什么 waypoint 可以按 namespace 共享？

2 分钟回答：作为资源边界代理，由目标资源选择使用；独立 scale/upgrade。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 51. [性能] 大量 access log 对数据面有什么影响？

2 分钟回答：格式化、IO、collector backpressure、磁盘/网络成本。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 52. [性能] 如何做 gateway capacity test ？

2 分钟回答：RPS/connection/TLS handshake/payload/protocol matrix + p99/CPU/memory。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 53. [源码] 如何定位 xDS NACK 是哪个资源 ？

2 分钟回答：istiod logs + proxy-status + Envoy config dump/version/nonce。

10 分钟深入：明确入口目录和对象：pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA，并从事件追踪到 ADS ACK。

验证方法：结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判：背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off：源码细节会随版本变化，面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 54. [网络] MTU 在多集群 mTLS 中怎么表现 ？

2 分钟回答：小包正常大包 reset/timeout；PMTU/fragmentation/overlay overhead。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**55. [AI Gateway] Istio 1.30 agentgateway 的定位？**

2 分钟回答：experimental Gateway API implementation，面向 AI agent/MCP；不是 sidecar/waypoint。

10 分钟深入：说明 Istio 1.30 agentgateway 是 experimental Gateway API implementation，面向 Agent/MCP 流量，仅 gateway 场景；不要扩展成 sidecar/waypoint 结论。

验证方向：GatewayClass、feature flag、官方 release notes 与 agentgateway 文档。

常见误判：把实验功能说成 Istio 默认数据平面。

Trade-off：新协议能力与成熟度、运维生态、兼容性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**56. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？**

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**57. [路由] Mirror 流量会不会影响主请求响应？**

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**58. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？**

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 59. [安全] 如何验证一个 Pod 当前拿到的证书？

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 60. [安全] 如何设计跨集群 CA？

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 61. [运维] 为什么 Helm values 漂移很危险？

2 分钟回答：base/istiod/gateway/CNI 独立生命周期导致 revision/ports/feature gates 不一致。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 62. [观测] 如何知道 endpoint 在远端 cluster？

2 分钟回答：proxy-config endpoints 的 locality/network/metadata + istiod registry。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 63. [多集群] 跨集群只单向可达怎么查？

2 分钟回答：两个方向 remote secret/API access/gateway/SG/route/CA 对称性。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 64. [ambient] Ambient 中 L7 policy enforcement 在哪里？

2 分钟回答：destination waypoint；ztunnel 只做 L4。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 65. [ambient] 为什么 waypoint 可以按 namespace 共享？

2 分钟回答：作为资源边界代理，由目标资源选择使用；独立 scale/upgrade。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**66. [性能] 大量 access log 对数据面有什么影响？**

2 分钟回答：格式化、IO、collector backpressure、磁盘/网络成本。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**67. [性能] 如何做 gateway capacity test？**

2 分钟回答：RPS/connection/TLS handshake/payload/protocol matrix + p99/CPU/memory。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**68. [源码] 如何定位 xDS NACK 是哪个资源？**

2 分钟回答：istiod logs + proxy-status + Envoy config dump/version/nonce。

10 分钟深入：明确入口目录和对象：pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA，并从事件追踪到 ADS ACK。

验证方法：结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判：背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off：源码细节会随版本变化，面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**69. [网络] MTU 问题在多集群 mTLS 中怎么表现？**

2 分钟回答：小包正常大包 reset/timeout；PMTU/fragmentation/overlay overhead。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 70. [AI Gateway] Istio 1.30 agentgateway 的定位？

2 分钟回答：experimental Gateway API implementation，面向 AI agent/MCP；不是 sidecar/waypoint。

10 分钟深入：说明 Istio 1.30 agentgateway 是 experimental Gateway API implementation，面向 Agent/MCP 流量，仅 gateway 场景；不要扩展成 sidecar/waypoint 结论。

验证方向：GatewayClass、feature flag、官方 release notes 与 agentgateway 文档。

常见误判：把实验功能说成 Istio 默认数据平面。

Trade-off：新协议能力与成熟度、运维生态、兼容性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 71. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 72. [路由] Mirror 流量会不会影响主请求响应？

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 73. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off: retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 74. [安全] 如何验证一个 Pod 当前拿到的证书？

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off: STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 75. [安全] 如何设计跨集群 CA？

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off: STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 76. [运维] 为什么 Helm values 漂移很危险？

2 分钟回答：base/istiod/gateway/CNI 独立生命周期导致 revision/ports/feature gates 不一致。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off: 升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 77. [观测] 如何知道 endpoint 在远端 cluster？

2 分钟回答：proxy-config endpoints 的 locality/network/metadata + istiod registry。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 78. [多集群] 跨集群只单向可达怎么查？

2 分钟回答：两个方向 remote secret/API access/gateway/SG/route/CA 对称性。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 79. [ambient] Ambient 中 L7 policy enforcement 在哪里？

2 分钟回答：destination waypoint；ztunnel 只做 L4。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 80. [ambient] 为什么 waypoint 可以按 namespace 共享？

2 分钟回答：作为资源边界代理，由目标资源选择使用；独立 scale/upgrade。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off: 资源与运维解耦收益, 对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

### 81. [性能] 大量 access log 对数据面有什么影响?

2 分钟回答: 格式化、IO、collector backpressure、磁盘/网络成本。

10 分钟深入: 拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模; 再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令: Envoy /stats; process CPU/memory; pilot metrics; config dump 大小; 负载测试。

常见误判: 只比较平均延迟, 忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off: 配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

### 82. [性能] 如何做 gateway capacity test?

2 分钟回答: RPS/connection/TLS handshake/payload/protocol matrix + p99/CPU/memory。

10 分钟深入: 拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模; 再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令: Envoy /stats; process CPU/memory; pilot metrics; config dump 大小; 负载测试。

常见误判: 只比较平均延迟, 忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off: 配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

### 83. [源码] 如何定位 xDS NACK 是哪个资源?

2 分钟回答: istiod logs + proxy-status + Envoy config dump/version/nonce。

10 分钟深入: 明确入口目录和对象: pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA, 并从事件追踪到 ADS ACK。

验证方法: 结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判: 背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off: 源码细节会随版本变化, 面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问: 如果这个问题发生在多集群、升级窗口或高并发场景, blast radius 会如何变化? 你会先收集哪三个证据, 再决定临时止血还是永久修复?

### 84. [网络] MTU 问题在多集群 mTLS 中怎么表现?

2 分钟回答: 小包正常大包 reset/timeout; PMTU/fragmentation/overlay overhead。

10 分钟深入: 区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径, 再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 85. [AI Gateway] Istio 1.30 agentgateway 的定位？

2 分钟回答：experimental Gateway API implementation，面向 AI agent/MCP；不是 sidecar/waypoint。

10 分钟深入：说明 Istio 1.30 agentgateway 是 experimental Gateway API implementation，面向 Agent/MCP 流量，仅 gateway 场景；不要扩展成 sidecar/waypoint 结论。

验证方向：GatewayClass、feature flag、官方 release notes 与 agentgateway 文档。

常见误判：把实验功能说成 Istio 默认数据平面。

Trade-off：新协议能力与成熟度、运维生态、兼容性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 86. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 87. [路由] Mirror 流量会不会影响主请求响应？

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**88. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？**

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**89. [安全] 如何验证一个 Pod 当前拿到的证书？**

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**90. [安全] 如何设计跨集群 CA？**

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**91. [运维] 为什么 Helm values 漂移很危险？**

2 分钟回答：base/istiod/gateway/CNI 独立生命周期导致 revision/ports/feature gates 不一致。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 92. [观测] 如何知道 endpoint 在远端 cluster ？

2 分钟回答：proxy-config endpoints 的 locality/network/metadata + istiod registry。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 93. [多集群] 跨集群只单向可达怎么查？

2 分钟回答：两个方向 remote secret/API access/gateway/SG/route/CA 对称性。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 94. [ambient] Ambient 中 L7 policy enforcement 在哪里？

2 分钟回答：destination waypoint；ztunnel 只做 L4。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 95. [ambient] 为什么 waypoint 可以按 namespace 共享？

2 分钟回答：作为资源边界代理，由目标资源选择使用；独立 scale/upgrade。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectrl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 96. [性能] 大量 access log 对数据面有什么影响？

2 分钟回答：格式化、IO、collector backpressure、磁盘/网络成本。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 97. [性能] 如何做 gateway capacity test？

2 分钟回答：RPS/connection/TLS handshake/payload/protocol matrix + p99/CPU/memory。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 98. [源码] 如何定位 xDS NACK 是哪个资源？

2 分钟回答：istiod logs + proxy-status + Envoy config dump/version/nonce。

10 分钟深入：明确入口目录和对象：pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA，并从事件追踪到 ADS ACK。

验证方法：结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判：背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off：源码细节会随版本变化，面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 99. [网络] MTU 问题在多集群 mTLS 中怎么表现？

2 分钟回答：小包正常大包 reset/timeout；PMTU/fragmentation/overlay overhead。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 100. [AI Gateway] Istio 1.30 agentgateway 的定位？

2 分钟回答：experimental Gateway API implementation，面向 AI agent/MCP；不是 sidecar/waypoint。

10 分钟深入：说明 Istio 1.30 agentgateway 是 experimental Gateway API implementation，面向 Agent/MCP 流量，仅 gateway 场景；不要扩展成 sidecar/waypoint 结论。

验证方向：GatewayClass、feature flag、官方 release notes 与 agentgateway 文档。

常见误判：把实验功能说成 Istio 默认数据平面。

Trade-off：新协议能力与成熟度、运维生态、兼容性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 101. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 102. [路由] Mirror 流量会不会影响主请求响应？

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off: retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 103. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off: retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 104. [安全] 如何验证一个 Pod 当前拿到的证书？

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off: STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 105. [安全] 如何设计跨集群 CA？

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off: STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 106. [运维] 为什么 Helm values 漂移很危险？

2 分钟回答：base/istiod/gateway/CNI 独立生命周期导致 revision/ports/feature gates 不一致。

10 分钟深入：revision canary、CRD/base/istiod/gateway/CNI 版本矩阵、proxy rollout、PDB/HPA、rollback 与 config validation。

验证命令：istioctl version/proxy-status/analyze；helm get values；kubectl get namespace --show-labels。

常见误判：只升级 istiod 镜像而忽略 gateway/CNI/CRD/revision tag。

Trade-off：升级速度与 blast radius；长期多 revision 会增加维护成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 107. [观测] 如何知道 endpoint 在远端 cluster ？

2 分钟回答：proxy-config endpoints 的 locality/network/metadata + istiod registry。

10 分钟深入：从 request RED 指标、Envoy cluster/listener stats、access log response flags、trace 到 control-plane push 指标建立证据链。

验证命令：Envoy /stats；Prometheus 查询；access log；istioctl pc；trace UI。

常见误判：只看 HTTP 503 数量，不看 response flag/upstream\_cluster/transport failure reason。

Trade-off：遥测覆盖率与代理 CPU、存储、网络、隐私成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 108. [多集群] 跨集群只单向可达怎么查 ？

2 分钟回答：两个方向 remote secret/API access/gateway/SG/route/CA 对称性。

10 分钟深入：先分 mesh/cluster/network，再分 control-plane topology；remote secret 用于 API discovery，east-west gateway 用于不同网络业务流量；最后讨论 CA/trust/network label。

验证命令：istioctl pc endpoints；kubectl get secret -l istio/multiCluster=true；检查 gateway 15443；远端 API Server 连通性。

常见误判：认为 remote secret 本身建立了业务隧道，或把 ingress gateway 与 east-west gateway 混为一谈。

Trade-off：multi-primary 故障域更独立但成本高；primary-remote 简化控制面但集中依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 109. [ambient] Ambient 中 L7 policy enforcement 在哪里 ？

2 分钟回答：destination waypoint；ztunnel 只做 L4。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 110. [ambient] 为什么 waypoint 可以按 namespace 共享？

2 分钟回答：作为资源边界代理，由目标资源选择使用；独立 scale/upgrade。

10 分钟深入：ztunnel 提供 per-node L4 secure overlay/HBONE，waypoint 提供可选 L7；说明 destination-oriented enforcement、CNI capture、sidecar 共存与迁移。

验证命令：kubectrl get ds ztunnel；istioctl ztunnel-config（按版本能力）；检查 Gateway waypoint 与 namespace labels；访问日志/metrics。

常见误判：认为 Ambient 完全没有 Envoy，或认为 ztunnel 可以执行 HTTP header/path 策略。

Trade-off：资源与运维解耦收益，对功能等价性、waypoint 容量和迁移验证提出新要求。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 111. [性能] 大量 access log 对数据面有什么影响？

2 分钟回答：格式化、IO、collector backpressure、磁盘/网络成本。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 112. [性能] 如何做 gateway capacity test？

2 分钟回答：RPS/connection/TLS handshake/payload/protocol matrix + p99/CPU/memory。

10 分钟深入：拆 sidecar CPU、TLS、协议解析、日志、filter 与 xDS 配置规模；再讨论 istiod push fan-out、endpoint churn 和 gateway capacity。

验证命令：Envoy /stats；process CPU/memory；pilot metrics；config dump 大小；负载测试。

常见误判：只比较平均延迟，忽略 p99、连接模型、payload、TLS handshake 和冷启动。

Trade-off：配置可见性、日志详细度、安全能力与性能成本。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

### 113. [源码] 如何定位 xDS NACK 是哪个资源？

2 分钟回答：istiod logs + proxy-status + Envoy config dump/version/nonce。

10 分钟深入：明确入口目录和对象：pilot-discovery/bootstrap、kube registry、model/PushContext、xds DiscoveryServer、pilot-agent、security CA，并从事件追踪到 ADS ACK。

验证方法：结合代码搜索、日志、pprof、Envoy config dump 与单元测试定位真实路径。

常见误判：背函数名但无法解释对象生命周期和并发/事件边界。

Trade-off：源码细节会随版本变化，面试回答应以稳定架构概念为主、函数路径为佐证。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 114. [网络] MTU 问题在多集群 mTLS 中怎么表现？

2 分钟回答：小包正常大包 reset/timeout；PMTU/fragmentation/overlay overhead。

10 分钟深入：区分应用 socket、iptables/CNI capture、Envoy listener、Kubernetes Service、跨节点/跨网络路径，再补充 MTU、conntrack、SG/NACL。

验证命令：iptables-save；ss -lntp；tcpdump；conntrack -S；istioctl pc listener/endpoint。

常见误判：ping/curl ClusterIP 成功就认为 sidecar 数据路径完全正常。

Trade-off：透明代理简化应用，但排障层次更多；CNI 降低 Pod 权限但增加 node agent 依赖。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 115. [AI Gateway] Istio 1.30 agentgateway 的定位？

2 分钟回答：experimental Gateway API implementation，面向 AI agent/MCP；不是 sidecar/waypoint。

10 分钟深入：说明 Istio 1.30 agentgateway 是 experimental Gateway API implementation，面向 Agent/MCP 流量，仅 gateway 场景；不要扩展成 sidecar/waypoint 结论。

验证方向：GatewayClass、feature flag、官方 release notes 与 agentgateway 文档。

常见误判：把实验功能说成 Istio 默认数据平面。

Trade-off：新协议能力与成熟度、运维生态、兼容性之间的平衡。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

#### 116. [路由] HTTP fault injection 和 retry 同时存在时应该关注什么？

2 分钟回答：故障注入位置、retry 条件、timeout budget、测试流量隔离。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**117. [路由] Mirror 流量会不会影响主请求响应？**

2 分钟回答：异步 shadow 语义与资源成本；目标服务可能被额外压测。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**118. [路由] PassthroughCluster 和 BlackHoleCluster 何时出现？**

2 分钟回答：outboundTrafficPolicy REGISTRY\_ONLY/ALLOW\_ANY 与未知外部目标。

10 分钟深入：先解释 VS 的 match/route 与 DR 的 subset/trafficPolicy，再落到 RDS weighted cluster、CDS cluster policy、EDS endpoint，最后讨论连接复用和统计采样。

验证命令：istioctl pc routes/clusters/endpoints；curl 循环采样；查看 access log upstream\_cluster。

常见误判：以 YAML 存在为证据，而不验证代理最终收到的 RDS/CDS/EDS。

Trade-off：retry/timeout 提升韧性但可能放大压力；细粒度路由提升控制力但增加配置复杂度。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**119. [安全] 如何验证一个 Pod 当前拿到的证书？**

2 分钟回答：proxy-config secret / config dump，查看 SAN、issuer、expiry、root。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

**120. [安全] 如何设计跨集群 CA？**

2 分钟回答：共享 root + 每集群 intermediate、私钥隔离、rotation、trust domain。

10 分钟深入：Kubernetes ServiceAccount/JWT -> CA -> SPIFFE SVID -> SDS -> Envoy mTLS，然后分 PeerAuthentication、RequestAuthentication、AuthorizationPolicy 的 enforcement 语义。

验证命令：istioctl pc secret；openssl s\_client；查看 PeerAuthentication/DR/AuthZ；istiod CA 日志。

常见误判：把 mTLS 成功等同于 AuthorizationPolicy 一定放行，或把证书当成 Pod IP 身份。

Trade-off：STRICT 安全性更强但迁移成本更高；共享 root 简化互信但扩大信任域。

Interviewer 继续追问：如果这个问题发生在多集群、升级窗口或高并发场景，blast radius 会如何变化？你会先收集哪三个证据，再决定临时止血还是永久修复？

## 23. Staff-Level 场景题：从故障到系统设计

### 全网 503，但 istiod/Envoy 都 Running

面试官期待：如何快速判断是 DNS、xDS、证书、gateway 还是应用？

回答主线：从 blast radius 开始：单 namespace/单 cluster/全 mesh；看 Envoy response flag 与 proxy-status，再按 LDS/RDS/CDS/EDS/SDS 收敛。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

### 发布 DestinationRule 后 p99 暴涨

面试官期待：为什么一个配置更新可能影响连接池和 LB？

回答主线：对比前后 cluster config；检查 connectionPool、HTTP2、TLS、outlier/locality；确认是否 full push 引起 proxy CPU 峰值。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

### Multi-cluster 只有 A->B 失败

面试官期待：为什么不要直接重签 CA？

回答主线：先验证远端 endpoint 是否在 A 的 EDS、gateway 是否可达、SNI/network metadata，再到 TLS。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

### Ambient 迁移后 HTTP AuthZ 失效

面试官期待：L4/L7 enforcement point 有什么变化？

回答主线：检查是否部署/绑定 waypoint；ztunnel 不解析 HTTP header/path。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

### istiod CPU 在滚动发布时打满

面试官期待：如何解释 endpoint churn 与 push fan-out？

回答主线：分析 EndpointSlice 事件率、connected proxies、push duration/config scope，并通过 discovery selectors/sidecar scope/扩容缓解。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

### Gateway 连接数持续增长

面试官期待：怎么区分正常长连接与泄漏？

回答主线：active cx、rq、duration、downstream/upstream close reason、keepalive、idle timeout、客户端行为。

- 证据：metrics -> proxy config -> access log -> packet/network -> application。
- Trade-off：临时止血与根因修复分开；避免只靠重启。

## 24. Hands-on Lab ( 30 ↑ )

26. Lab 1: 安装 Sidecar profile，并对比注入前后 PodSpec。
27. Lab 2: 抓取并解释 istio-proxy bootstrap。
28. Lab 3: 用 iptables-save 画出 outbound/inbound 重定向链。
29. Lab 4: 创建 90/10 VirtualService，并用 1000 次请求验证分布。
30. Lab 5: 给 v2 设置故障注入并观察 retry/timeout。
31. Lab 6: 配置 connectionPool/outlierDetection，主动触发 UO/UH。
32. Lab 7: 用 proxy-config listeners/routes/clusters/endpoints 还原一次请求路径。
33. Lab 8: 配置 STRICT mTLS 并验证证书 SAN。
34. Lab 9: 故意制造 DestinationRule TLS mismatch 并定位。
35. Lab 10: 配置 AuthorizationPolicy 按 namespace/principal 限制。
36. Lab 11: 配置 ingress gateway + TLS termination。
37. Lab 12: 配置 TLS passthrough。
38. Lab 13: 通过 ServiceEntry 访问外部域名。
39. Lab 14: 搭建 egress gateway 并验证出口 IP。
40. Lab 15: 创建两个 kind 集群做 same-network multicluster。
41. Lab 16: 搭建 multi-network + east-west gateway。
42. Lab 17: 删除 remote secret，观察远端 endpoint 消失。
43. Lab 18: 破坏 CA trust，捕获 TLS handshake error。
44. Lab 19: 验证 locality-aware endpoint metadata。
45. Lab 20: 安装 Ambient profile，观察 ztunnel。
46. Lab 21: 给 namespace 打 ambient label，验证无 sidecar mTLS。
47. Lab 22: 创建 waypoint 并启用 HTTP route。
48. Lab 23: 比较 sidecar 与 ambient 的 CPU/memory。
49. Lab 24: 进行 revision canary upgrade。
50. Lab 25: 故意让 proxy 连旧 revision，练习 proxy-status。
51. Lab 26: 制造 xDS NACK 并从日志定位。
52. Lab 27: 开启 access log，学习 NR/UH/UF/UO。
53. Lab 28: 接入 Prometheus/OTel，建立 mesh SLO dashboard。
54. Lab 29: 阅读 pilot/pkg/xds 关键流程并画调用图。
55. Lab 30: 写一个完整的多集群故障演练 runbook。

## 25. 30 天冲刺计划

| 天数    | 主题                           | 每日输出                                 |
|-------|------------------------------|--------------------------------------|
| 1-4   | 架构 + 注入 + iptables           | 手画 3 张图；完成 Labs 1-3                  |
| 5-8   | xDS + Envoy config graph     | 能从 YAML 推导 LDS/RDS/CDS/EDS           |
| 9-12  | Traffic Management           | 完成 90/10、retry、timeout、CB/outlier 实验 |
| 13-15 | Security                     | 证书、mTLS、AuthN/AuthZ、TLS 故障           |
| 16-19 | Gateway/Egress/Observability | 入口/出口 + response flags + dashboard   |
| 20-23 | Multicluster                 | remote secret、east-west、TLS/网络排障     |
| 24-26 | Ambient                      | ztunnel/HBONE/waypoint + sidecar 对比  |
| 27-28 | 源码                           | pilot-discovery/xDS/agent 主路径        |
| 29    | System Design                | 100k Pods / 3 region mesh 白板题        |
| 30    | Mock Interview               | 2min/10min 回答 + 故障树复盘                |

## 26. Cheat Sheet : 生产排障最常用命令与检查点

### 26.1 控制平面

```
kubectl -n istio-system get pod -l app=istiod -o wide
istioctl proxy-status
istioctl analyze -A
kubectl -n istio-system logs deploy/istiod | grep -Ei 'error|nack|push|ads|ca'
```

### 26.2 数据平面

```
istioctl pc listeners POD -n NS
istioctl pc routes POD -n NS
istioctl pc clusters POD -n NS
istioctl pc endpoints POD -n NS
istioctl pc secret POD -n NS
kubectl exec POD -c istio-proxy -- curl -s localhost:15000/stats
kubectl exec POD -c istio-proxy -- curl -s localhost:15000/config_dump
```

### 26.3 Kubernetes / Network

```
kubectl get svc,endpointsllice,pod -A -o wide
kubectl describe pod POD -n NS
nsenter -t <pid> -n ss -lntp
iptables-save | grep ISTIO
conntrack -S
tcpdump -ni any port 15001 or port 15006 or port 15443
```

## 27. Research Notes / 2026 版本基线

本手册以 2026-08-31 时点的官方文档为技术基线：Istio 1.30 于 2026-05-18 发布，官方说明其支持 Kubernetes 1.32-1.36；1.30 引入实验性的 agentgateway GatewayClass，并继续增强 Gateway API、TLSRoute 与 Ambient 能力。Ambient 架构以 per-node ztunnel 提供 L4 secure overlay，并在需要 L7 时引入 waypoint Envoy。

对于 Sidecar multicluster，官方仍覆盖 multi-primary / primary-remote 以及 same-network / multi-network 组合；不同网络通过 east-west gateway 进行业务流量连接。对于 Ambient multicluster 当前官方安装文档明确采用 multi-primary 模型。

面试准备时要把“当前稳定能力”和“实验/预览能力”分开表述，并在回答中给出版本边界。

## 28. 最终复习清单

- ☐ 能在 5 分钟内画出 Sidecar 与 Ambient 两套架构图。
- ☐ 能从 Pod 创建解释到 Envoy ready 的 admission/injection/agent/xDS 链。
- ☐ 能解释一条请求如何经过 Listener -> Route -> Cluster -> Endpoint。
- ☐ 能明确 VS 与 DR 的职责边界并从 YAML 推导 xDS。
- ☐ 能解释 SPIFFE identity、SDS、mTLS 与 AuthZ。
- ☐ 能解释 ingress、egress、east-west gateway 三者职责差异。
- ☐ 能解释 multi-primary/primary-remote 与 network topology。
- ☐ 能从 503 response flag 开始建立故障树。
- ☐ 能定位 remote endpoint、TLS、network gateway、CA 的跨集群故障。
- ☐ 能解释 ztunnel/HBONE/waypoint 的职责边界。
- ☐ 能说清 revision canary upgrade 与 rollback。
- ☐ 能阅读 pilot/xDS/agent 核心源码并追踪一次配置变更。
- ☐ 能给出 control-plane 与 data-plane 的容量指标和 SLO。
- ☐ 能设计 100k Pod、多 region、多租户 mesh 并讨论 trade-off。
- ☐ 能用 2 分钟回答核心题，用 10 分钟深入到源码、命令、指标、故障案例。

**最终目标** 不要把 Istio 面试看成 CRD 记忆题。真正的 Senior/Staff 能力是：看到一个请求失败时，能在 Kubernetes 对象、Istio 配置、xDS、Envoy、TLS、Linux 网络、跨集群拓扑之间建立一条可验证的因果链。